



Deploying Security at Scale

Chris Swan, VP CTO GIS
@cpswan

Why Me?



Disclaimer... Presently checked out



Agenda

Build in or bolt on – the audit paradox

API enabled – Let's Encrypt

We're not done yet



The Audit Paradox

Building in



CC photo by WorldSkills

What building in looks like

Message Validation

Message validation is used to protect your service from malformed messages and message parameters. Message schemas can be used to validate incoming messages, and custom validators can be used to validate parameter data before your service consumes it. Do not trust input from any source that the client can influence, such as cookies, headers, IP address, or the content of messages sent to your service. Do trust input from a database, the file system, or anything else outside the trust boundary of your service. Use message schemas and data validators to check for format, range, length, and type. Do not rely on client-side validation; make all security decisions based on server-side validation.

Consider the following guidelines:

- **Do not trust input.**
- **Verify the message payload against a schema.**
- **Verify the message size, content, and character sets.**
- **Filter, scrub, and reject input and output before additional processing.**

Do Not Trust Input

An attacker passing malicious input can attempt SQL injection, cross-site scripting, and other injection attacks that aim to exploit your application's vulnerabilities. Check for known good data and constrain input by validating it for type, length, format, and range.

Verify the Message Payload Against a Schema

If you need to validate parameters, message contracts, or data contracts passed to operations, use schemas to validate the incoming message. Schemas provide a wide range of input validation without the need for custom code or validation routines.

Verify the Message Size, Content, and Character Sets

Validate incoming messages to ensure that they match your expectations regarding size, content, and character encoding. If a message is much larger than expected or contains encoding other than what your service expects, you may be under attack. Reject the message and log the occurrence so that auditing can determine if an attack is underway.

Bolting on

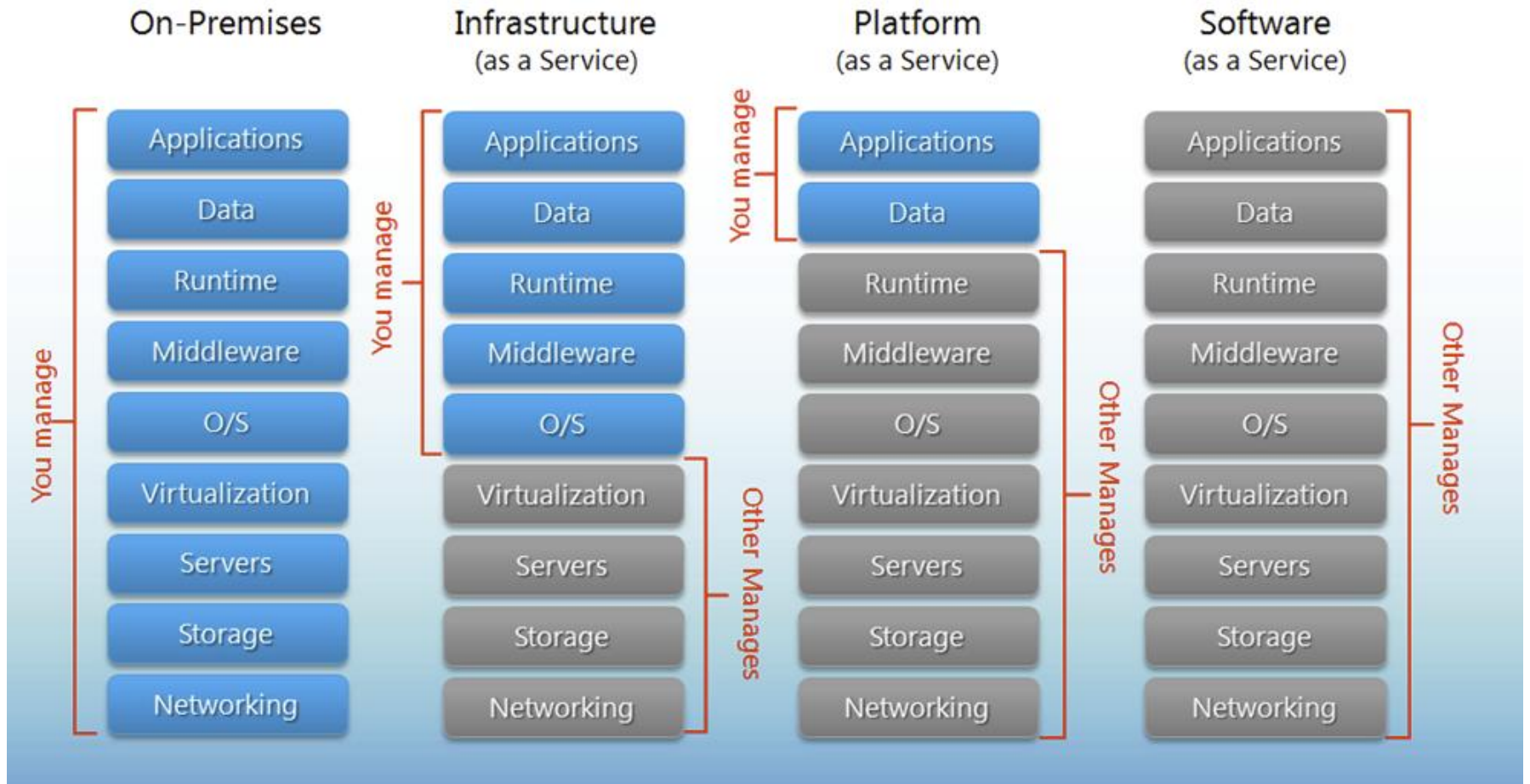


CC photo by arbyreed

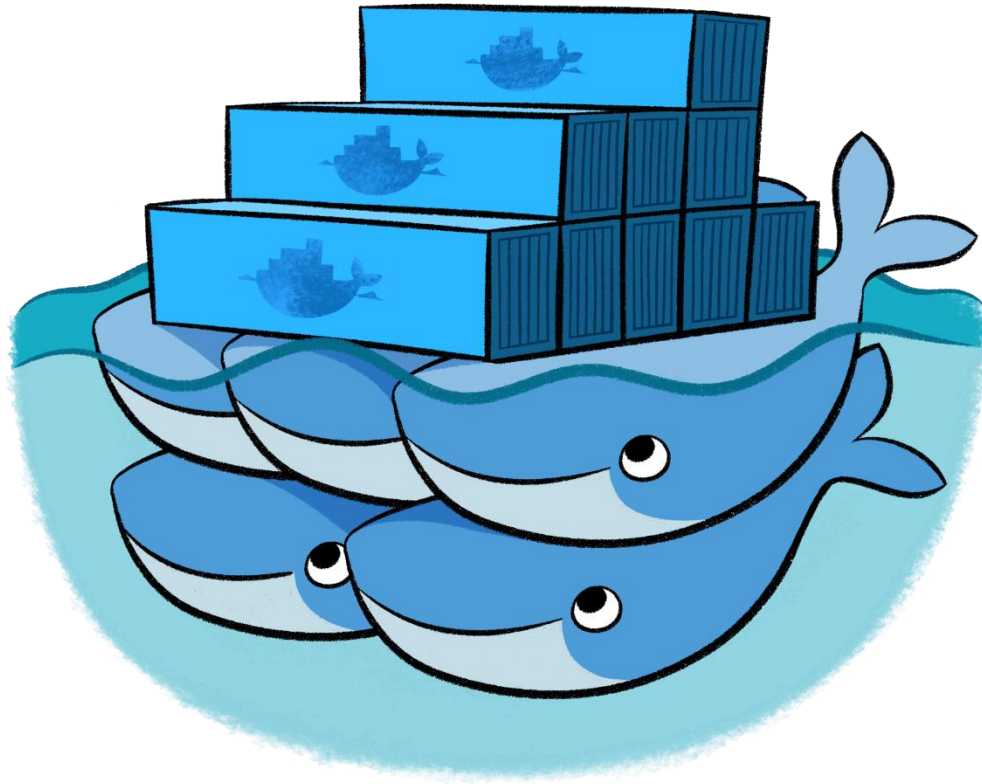
What bolting on looks like



PaaS gives us a chance to bolt in



But Docker adoption shows a movement against opinionated platforms





Certificates

Who remembers this company?



Things worked out better for this chap



Because he got to go to space



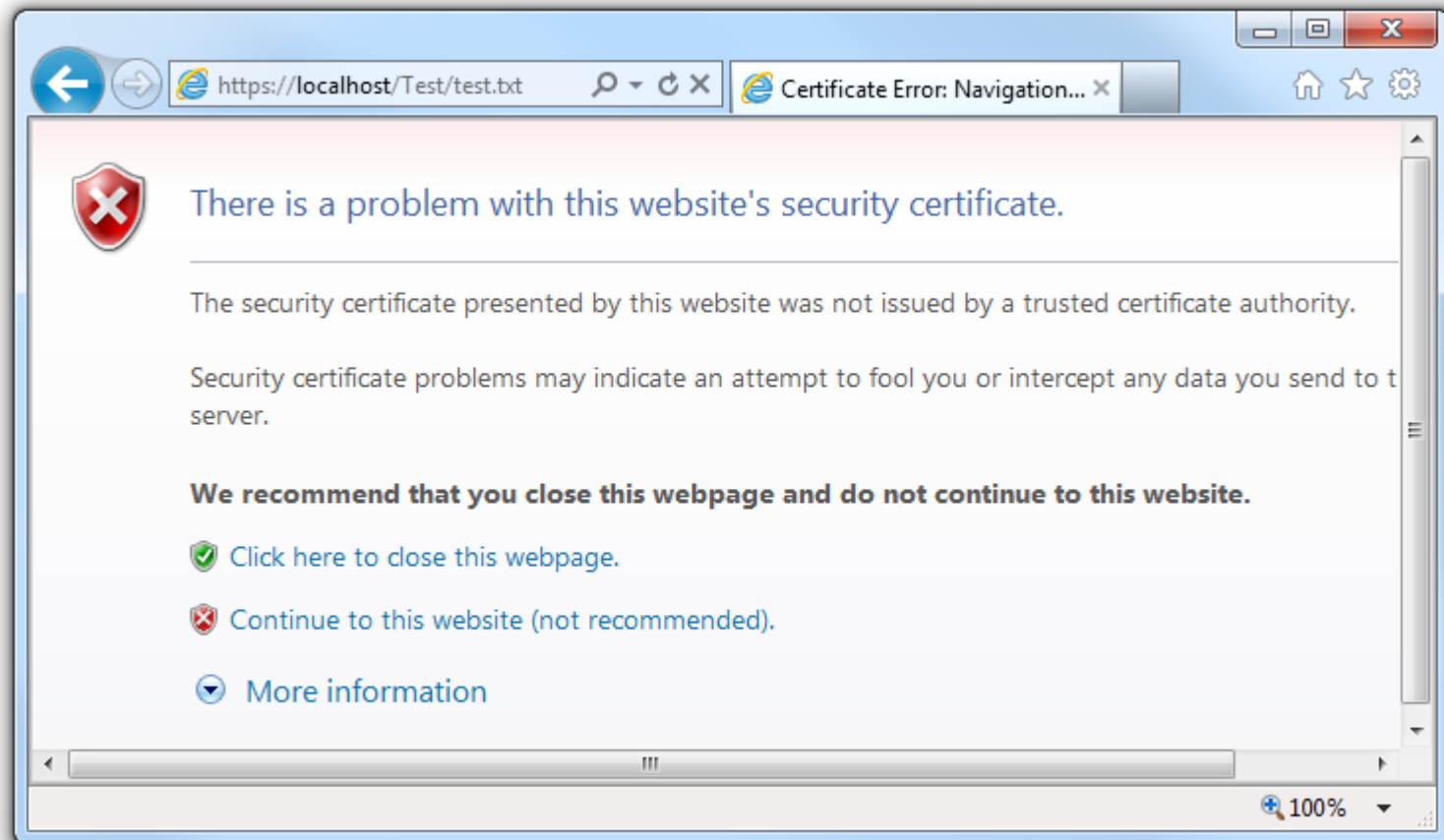
The sticker cost

				Most Secure	
	Secure Site	Secure Site Pro	Secure Site with EV	Secure Site Pro with EV	Secure Site Wildcard
Buy Now	BUY NOW	BUY NOW	BUY NOW	BUY NOW	BUY NOW
Renew Now	RENEW	RENEW	RENEW	RENEW	RENEW
Price: 1 year	£259	£599	£599	£899	£1,299

Alternatively

```
openssl req \  
    -newkey rsa:2048 -nodes -keyout domain.key \  
    -x509 -days 365 -out domain.crt
```

But



Sidebar... we should really be using



CONVERGENCE

But now certificates are free



Let's Encrypt



CLOUDFLARE



AWS Certificate Manager

Well, actually they have been for ages

The logo for startSSL, featuring the word "start" in dark blue lowercase letters, "SSL" in green uppercase letters, and a registered trademark symbol (®) in dark blue. The entire logo is set against a light blue rectangular background.

But there's a difference now



CC BY-SA 2.0 image by Aaron Fulkerson <https://flic.kr/p/9F3a2b>

It's as much about ease of consuming APIs



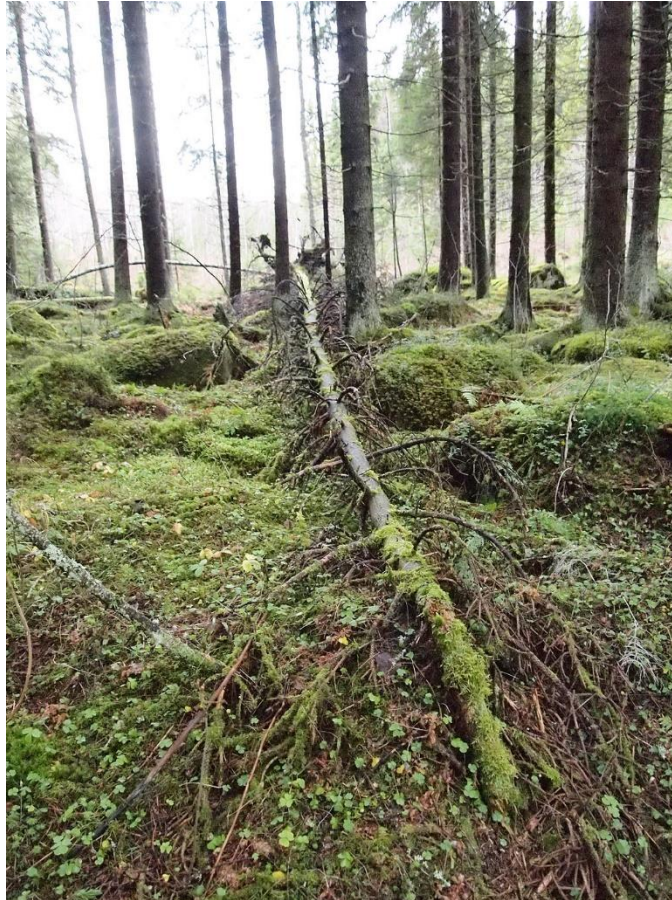
Automatically enable HTTPS on your website with EFF's Certbot,
deploying [Let's Encrypt](#) certificates.

I'm using on



Not so fast...

If a security events happens and it isn't monitored



ToDo: SecDevOps



APIs are necessary but not sufficient:
Need to have them integrated into the
overall system



Control metadata (and its mutability):
Must be visible and understandable



Security events need to be captured:
Then turned into something humans can
action



Summing up

You have been watching

Build in or bolt on – the audit paradox

API enabled – Let's Encrypt

We're not done yet



Thank you for listening



Questions?